

信息安全事件响应与升级手册

本手册规定安全事件的发现、分级、通知、处置、恢复和复盘流程，适用于账号异常、数据泄露、恶意软件、生产系统入侵和错误权限配置等场景。

1. 事件分级

P1 为最高等级事件，包括核心业务中断、确认发生的大规模客户数据泄露或仍在扩散的生产系统入侵。P2 表示影响受控但需要跨团队协作，P3 表示局部低风险异常。等级由值班负责人初判，事件指挥官可以根据影响范围调整。

2. P1 首要时限

P1 事件必须在发现后 15 分钟内通知信息安全值班负责人，并在 30 分钟内建立处置群。处置群中必须明确事件指挥官、技术负责人、记录员和业务联络人。任何人不得因等待根因确认而延迟通知。

关键证据：发现时间、告警截图、受影响资产、已采取动作和联系人。

时钟从首次确认异常开始计算，不因交接班或团队边界暂停。

3. 发现与报告

员工发现可疑登录、异常下载、恶意邮件或数据误发时，应立即停止高风险操作，通过安全热线或事件系统报告。报告中写明时间、系统、账号、现象和已采取动作。

3.1 初始证据

保留原始日志、截图和告警编号，不要为了整理材料而删除现场数据。涉及个人设备时，不得自行上传敏感内容到公共网盘。

4. 遏制动作

技术负责人根据影响范围选择冻结账号、隔离主机、撤销令牌、限制网络访问或暂停接口。所有动作都应记录执行人和时间。

5. 调查与沟通

事件指挥官维护统一时间线。业务联络人负责向受影响团队同步事实，不得发布未经确认的根因。涉及客户数据时，由法务和隐私负责人共同判断通知义务。

5.1 升级条件

影响扩大、证据显示持续外传、关键系统无法恢复或媒体已经关注时，应立即升级等级。P2 升级为 P1 后，重新按 P1 时限补齐角色和处置群。

6. 恢复条件

恢复前必须确认攻击路径被阻断、凭证已轮换、关键日志仍可追溯，并完成业务负责人验证。恢复应分批执行并准备回滚方案。

7. 分级与响应矩阵

等级	典型影响	首次通知	处置群	复盘
P1	核心中断或重大数据事件	15 分钟	30 分钟	48 小时内
P2	局部中断或风险受控	30 分钟	60 分钟	5 个工作日
P3	低风险异常或单点问题	4 小时	按需	月度汇总

8. 跨页调查记录

调查记录应从最早告警开始建立统一时间线，逐项记录账号活动、网络连接、文件访问、权限变化和处置动作。记录员需要区分已确认事实、工作假设和待验证问题，任何结论都应链接到日志、工单或取证文件。若调查跨越多个系统，事件指挥官应指定每个系统的证据负责人，并使用统一时区，避免时间线错位。

8. 跨页调查记录 (续)

交接班时，上一班负责人必须说明当前影响、已完成动作、尚未验证的假设和下一步计划。新的负责人确认接收后，才能结束本轮值守。证据副本应存放在受控位置，文件名包含事件编号和采集时间，未经授权不得发送到外部协作工具。

9. 恢复与关闭

事件关闭前应确认业务恢复、监控稳定、临时权限回收、客户沟通完成和整改负责人明确。P1 事件应在 48 小时内组织复盘，复盘关注机制和系统缺口，不以追究个人责任代替根因分析。

10. 复盘清单

1. 确认发现渠道是否及时，告警是否需要补充。
2. 确认 15 分钟通知和 30 分钟建群是否达成。
3. 确认遏制动作是否造成额外业务影响。
4. 为每项整改指定负责人、截止时间和验证方式。

11. 文档维护

本手册每半年复审一次。发生 P1 事件或组织职责调整后，应在复盘完成后的十个工作日内更新联系人、升级路径和证据模板。